

Encuesta Integral sobre Indicadores CWE y Gestión de Debilidades de Software y Hardware

0. Introducción para la organización encuestada

Esta encuesta busca comprender cómo su organización integra el **marco CWE** (Common Weakness Enumeration) y, en general, la gestión de debilidades de software y hardware en sus prácticas de ciberseguridad, desarrollo, operación y gobierno corporativo. No se trata de un examen, sino de un espejo estadístico: cuanto más honestas sean las respuestas, más útil será el panorama resultante.

Los resultados se utilizarán de forma agregada y anónima para elaborar indicadores sectoriales y nacionales, alineados con las tendencias internacionales en CWE y vulnerabilidades (CVE, CVSS, KEV, etc.). Ninguna respuesta individual será publicada ni asociada a la organización sin su consentimiento expreso.

Por favor, responda pensando en la realidad actual, no en la deseable. Las aspiraciones son muy loables, pero las métricas se llevan mejor con los hechos.

1. Datos generales de la organización

1.1. Sector principal de actividad de la organización

Seleccione el sector que mejor describa su actividad principal.

- Administración pública
- Sanidad
- Energía
- Transporte y logística
- Finanzas y seguros
- Industria y manufactura
- Telecomunicaciones
- Tecnología y servicios digitales
- Educación e investigación
- Otros (especificar): _____

1.2. Tamaño aproximado de la organización (en personas)

- Menos de 50
- 50–249
- 250–999
- 1.000–4.999
- 5.000–19.999
- 20.000 o más

1.3. Naturaleza de los sistemas críticos gestionados

Puede marcar varias opciones.

- Sistemas que procesan datos personales sensibles (salud, menores, justicia, etc.)
- Sistemas que soportan servicios esenciales (NIS2, operadores de servicios esenciales, infraestructuras críticas)
- Plataformas de comercio electrónico o financieros
- Sistemas de control industrial (ICS/OT)
- Plataformas cloud ofrecidas a terceros
- Ninguno de los anteriores / sistemas mayoritariamente internos

1.4. Rol de la persona que cumplimenta la encuesta

- CISO / Responsable máximo de ciberseguridad
- Responsable de seguridad de la información (no CISO)
- Responsable de desarrollo / arquitectura de software
- Responsable de operaciones / infraestructura
- Auditoría / cumplimiento normativo
- Otro (especificar): _____

2. Gobierno y estrategia de gestión de debilidades (CWE como lenguaje)

2.1. ¿La organización utiliza el marco CWE como taxonomía de referencia para clasificar debilidades de software y/o hardware?

- Sí, de manera sistemática en todos los procesos relevantes
- Sí, pero solo en algunos procesos o proyectos específicos
- No, pero utilizamos otra taxonomía estructurada (especificar cuál)
- No, usamos descripciones libres sin taxonomía formal
- No lo sé / no se aplica

Si no utiliza CWE: ¿cuál es la principal razón?

- Falta de conocimiento sobre CWE
- Falta de herramientas que lo soporten
- Percepción de complejidad o poca utilidad práctica
- Preferencia por estándares internos o sectoriales
- Otros (especificar): _____

2.2. ¿Existe una política o norma interna que regule explícitamente la gestión de “debilidades” (weaknesses) más allá de simples “vulnerabilidades” (vulnerabilities)?

- Sí, política formal aprobada por la alta dirección
- Sí, documentación técnica/procedimental, pero no elevada a política de alto nivel
- No, se gestiona de forma ad-hoc según cada proyecto
- No, solo tratamos vulnerabilidades concretas cuando aparecen
- No lo sé

2.3. ¿Se ha integrado la gestión de debilidades CWE en la estrategia corporativa de ciberseguridad o resiliencia digital?

- Sí, de forma explícita (mencionada en la estrategia o planes directores)
- Sí, de forma implícita (se trabaja, pero no se menciona por nombre)
- No, aún no
- No lo sé

Si la respuesta es “sí, explícita”, indique brevemente en qué documentos se recoge:

2.4. Nivel de prioridad interna asignado a la reducción de debilidades de diseño e implementación (CWE)

Indique cómo describiría la prioridad estratégica:

- Prioridad muy alta, con objetivos medibles y seguimiento periódico
- Prioridad alta, con iniciativas claras pero sin métricas formales
- Prioridad media, se aborda cuando coincide con otros objetivos
- Prioridad baja, se atiende de forma reactiva
- No es un área prioritaria identificada

3. Procesos de identificación y clasificación de debilidades (CWE-CVE-CVSS)

3.1. ¿Cómo identifica habitualmente la organización debilidades de software y hardware?

Puede marcar varias.

- Análisis estático de código (SAST)
- Análisis dinámico (DAST, IAST, fuzzing)
- Pruebas de penetración internas
- Pruebas de penetración externas / Red teaming
- Revisión manual de código / arquitectura
- Programas de bug bounty o divulgación responsable
- Información de proveedores o fabricantes
- Incidentes reales y análisis post mortem
- No se realiza identificación sistemática

3.2. Cuando se identifica una vulnerabilidad (CVE o equivalente), ¿se mapea sistemáticamente a una categoría CWE?

- Sí, siempre que sea posible
- Sí, en la mayoría de los casos relevantes
- Solo para vulnerabilidades críticas
- No, raramente o nunca
- No lo sé

En caso de que sí se mapee a CWE:

- Se hace de forma manual por analistas
- Se hace de forma automática por herramientas
- Se hace de forma híbrida (herramienta + revisión manual)

3.3. ¿Se utilizan métricas basadas en CWE para describir el perfil de debilidades de la organización?

Por ejemplo, “X% de nuestras vulnerabilidades son de inyección, Y% de autenticación, etc.”

- Sí, con métricas consolidadas y reportes periódicos
- Sí, pero de forma casi artesanal / puntual
- No, pero nos gustaría incorporarlas en los próximos 2 años
- No, no contemplamos utilizar este tipo de métricas
- No lo sé

3.4. ¿Se combinan CWE con CVE y CVSS en un mismo cuadro de mando o repositorio central de vulnerabilidades?

- Sí, de forma integrada (CWE, CVE, CVSS aparecen juntos)
- Parcialmente (por ejemplo, solo CVE y CVSS, o CWE en proyectos específicos)
- No, se gestionan por separado o en diferentes herramientas
- No lo sé

4. Uso de listas CWE priorizadas (Top 25, KEV, MIHW)

4.1. ¿Conoce la organización el “CWE Top 25 Most Dangerous Software Weaknesses” publicado por MITRE anualmente?

- Sí, y lo utilizamos activamente
- Sí, lo conocemos pero no se utiliza de forma sistemática
- He oído hablar de ello / lo conoce el equipo técnico, pero no se usa
- No, no lo conocíamos hasta ahora

4.2. ¿Se ha adoptado el Top 25 como referencia para priorizar actividades de seguridad?

Por ejemplo, formación, pruebas de seguridad, requisitos de herramientas, etc.

- Sí, es un marco explícito de priorización
- Sí, parcialmente, para algunos proyectos o sistemas críticos
- No, priorizamos por otros criterios (por ejemplo, solo CVSS)
- No, no utilizamos listas priorizadas
- No lo sé

Si la respuesta es afirmativa, indique en qué ámbitos se utiliza:

- Definición de requisitos para herramientas de análisis
- Formación de desarrolladores y arquitectos
- Priorización de correcciones
- Auditorías y revisiones técnicas
- Otros (especificar): _____

4.3. ¿Se tiene en cuenta la lista de vulnerabilidades activamente explotadas (KEV) y su mapeo a CWE para priorizar parches y mitigaciones?

- Sí, utilizamos KEV y su relación con CWE para priorizar
- Sí, utilizamos KEV, pero no trabajamos explícitamente con CWE
- No, no utilizamos KEV de forma sistemática
- No lo sé

4.4. Si la organización diseña o integra hardware, ¿conoce y utiliza la lista “Most Important Hardware Weaknesses (MIHW)” de CWE?

- Sí, la conocemos y se utiliza en diseño/verificación
- Sí, la conocemos, pero su uso es limitado o experimental
- No, pero podría ser relevante
- No, y no lo consideramos relevante

5. Indicadores y métricas internas basadas en CWE

5.1. ¿La organización calcula métricas de “prevalencia de debilidades” basadas en CWE?

Por ejemplo, número o porcentaje de debilidades por tipo de CWE, por aplicación, por línea de código, etc.

- Sí, de forma estructurada y periódica (mensual, trimestral, anual)
- Sí, pero solo en ciertos proyectos / áreas
- No, pero tenemos previsto hacerlo
- No, y no está previsto
- No lo sé

En caso afirmativo, indique qué tipo de métricas se calculan habitualmente:

5.2. ¿Se definen objetivos de reducción de debilidades (por ejemplo, “reducir en X% las debilidades de autenticación en dos años”)?

- Sí, con objetivos cuantificados y plazos definidos
- Sí, pero en términos más cualitativos (“mejorar”, “reforzar”)
- No, aunque sería deseable
- No, no es algo que se mida
- No lo sé

5.3. ¿Se mide el tiempo medio de remediación de debilidades agrupadas por CWE?

- Sí, es un indicador estándar de gestión
- Sí, de forma parcial (solo para críticas o para algunos sistemas)
- No, solo medimos tiempos de remediación de “vulnerabilidades” sin clasificar
- No, no se hacen mediciones de este tipo
- No lo sé

5.4. ¿Se analizan tendencias temporales (año a año) en el perfil de debilidades CWE de la organización?

- Sí, disponemos de series temporales y análisis de tendencias
- Sí, pero solo mediante análisis manuales esporádicos
- No, solo tenemos fotos puntuales sin histórico consolidado
- No, no recogemos datos
- No lo sé

5.5. ¿Se comparan las métricas internas basadas en CWE con referencias externas (por ejemplo, el Top 25 global o informes sectoriales)?

- Sí, de forma sistemática (benchmarking periódico)
- Sí, pero solo en ejercicios de auditoría o revisiones especiales
- No, no realizamos comparaciones externas
- No, no, pero nos interesaría hacerlo
- No lo sé

6. Integración de CWE en el ciclo de vida de desarrollo (SDLC)

6.1. ¿El ciclo de vida de desarrollo de software (interno o contratado) incorpora explícitamente la prevención de debilidades CWE?

- Sí, en todas las fases (requisitos, diseño, desarrollo, pruebas, despliegue)
- Sí, pero principalmente en fase de pruebas
- Sí, pero solo en algunos proyectos de alta criticidad
- No, no se menciona de forma explícita
- No lo sé

6.2. ¿Se utilizan guías de codificación segura o patrones de diseño alineados con CWE?

- Sí, guías internas propias alineadas con CWE
- Sí, guías externas (OWASP, CERT, etc.) con referencias a CWE
- No, tenemos guías, pero sin referencia a CWE
- No, no disponemos de guías formales
- No lo sé

6.3. ¿Las herramientas de análisis estático/dinámico utilizadas mapean sus hallazgos a CWE?

- Sí, y explotamos esa información en nuestros informes
- Sí, pero no aprovechamos el mapeo más allá de la propia herramienta
- No, nuestras herramientas no trabajan con CWE
- No lo sé

6.4. ¿Se ha definido alguna lista interna de “CWE prioritarios” derivados del contexto de la organización o del sector?

- Sí, existe una lista priorizada (incluso aunque se base en el Top 25)
- Sí, de manera informal, conocida por el equipo técnico
- No, pero sería útil contar con ella
- No, no se considera necesario
- No lo sé

7. Integración de CWE en la gestión de riesgos y cumplimiento normativo

7.1. ¿Se incorporan debilidades CWE en los análisis de riesgos de seguridad de la información o ciberseguridad?

- Sí, se identifican y valoran riesgos vinculados a tipos concretos de CWE
- Sí, pero de forma indirecta (se habla de “vulnerabilidades” sin taxonomía formal)
- No, los análisis de riesgo son más genéricos
- No lo sé

7.2. ¿Se vinculan debilidades CWE con requisitos del Esquema Nacional de Seguridad (ENS) u otros marcos normativos aplicables?

- Sí, existe un mapeo formal interno (ENS, ISO 27001, NIS2, etc.)
- Sí, de forma parcial o en guías técnicas
- No, pero podría ser útil
- No, no lo consideramos
- No lo sé

7.3. ¿Los informes internos para alta dirección incluyen algún indicador basado en CWE?

- Sí, de manera explícita (por ejemplo, “Top 10 de debilidades CWE de la organización”)
- Sí, de manera indirecta (simplificado o reetiquetado)
- No, solo se reporta a alto nivel (número de vulnerabilidades, incidencias, etc.)
- No lo sé

8. Capacidades, formación y cultura en torno a CWE

8.1. ¿El personal técnico (desarrolladores, arquitectos, analistas de seguridad) ha recibido formación específica sobre CWE?

- Sí, formación formal recurrente
- Sí, formación puntual
- No, pero está planificada
- No, y no está prevista
- No lo sé

8.2. ¿Se utilizan las categorías CWE para estructurar contenidos de formación y concienciación?

- Sí, se utilizan debilidades típicas (inyección, autenticación, etc.) como hilo conductor
- Sí, pero solo en formaciones muy técnicas
- No, los contenidos son más genéricos o basados en casos
- No lo sé

8.3. ¿Se promueve que los equipos conozcan las listas Top 25, KEV y MIHW como parte de su cultura de seguridad?

- Sí, se comunican y discuten regularmente
- Sí, pero de forma informal
- No, no forman parte de la cultura habitual
- No lo sé

9. Tecnología, herramientas y datos para indicadores CWE

9.1. ¿Cuenta la organización con un repositorio centralizado de vulnerabilidades que permita registrar CWE para cada entrada?

- Sí, repositorio unificado con campos para CWE, CVE, CVSS, etc.
- Sí, pero se usan varios repositorios no totalmente integrados
- No, la información se dispersa en diferentes herramientas
- No, no llevamos un registro sistemático
- No lo sé

9.2. ¿Existen APIs, procesos ETL o integraciones que permitan extraer datos de CWE para análisis y generación de indicadores?

- Sí, contamos con integraciones automatizadas
- Sí, pero requieren mucho trabajo manual
- No, la explotación de datos es manual
- No lo sé

9.3. ¿Se han definido criterios de calidad de datos para la clasificación de debilidades y vulnerabilidades (incluido CWE)?

- Sí, con roles claros de revisión y validación
- Sí, pero de manera poco formal
- No, cada equipo registra “como puede”
- No lo sé

10. Perspectiva futura, inversión e impacto (IGM y ROI)

10.1. ¿La organización mide el impacto económico de las debilidades y vulnerabilidades (costes de incidentes, mitigaciones, etc.)?

- Sí, disponemos de estimaciones o modelos de coste
- Sí, pero solo para incidentes graves
- No, solo medimos en términos cualitativos
- No, no medimos impacto económico
- No lo sé

10.2. ¿Se ha evaluado el retorno de la inversión (ROI) de iniciativas destinadas a reducir debilidades CWE específicas?

- Sí, con modelos cuantitativos (por ejemplo, reducción de incidentes)
- Sí, de manera aproximada o cualitativa
- No, aún no
- No, y no se considera necesario
- No lo sé

10.3. ¿Se prevé aumentar, mantener o reducir la inversión en herramientas y procesos relacionados con CWE en los próximos 2-3 años?

- Aumentar significativamente
- Aumentar moderadamente
- Mantener aproximadamente
- Reducir
- No lo sabemos todavía

10.4. En una escala de 1 a 5, ¿hasta qué punto considera que una gestión más madura de CWE puede mejorar la resiliencia y competitividad de la organización?

- 1 – Muy poco
- 2 – Poco
- 3 – Moderadamente
- 4 – Bastante
- 5 – Mucho

11. Comentarios abiertos

11.1. ¿Qué barreras principales encuentra su organización para adoptar mejor CWE y métricas de debilidades?

11.2. ¿Qué tipo de apoyo (guías, herramientas, formación, regulación clara, etc.) facilitaría el uso de indicadores CWE a nivel organizativo?

11.3. Si lo desea, añada cualquier comentario adicional, reflexión o crítica constructiva sobre este enfoque de indicadores CWE.
